



women

1. API Route Protection (Authentication & Authorization)

Abhi /api/upload jaise sensitive routes bina login ke accessible ho sakte hain. Humein:

Session Checks: Har sensitive API route (upload, delete, edit) par getSession use karke check karna chahiye ki user logged in hai ya nahi.

Role-Based Access (RBAC): Yeh ensure karna ki sirf admin hi users ko delete kar sake ya content moderate kar sake.

2. File Validation & Hardening (Upload Security)

Video upload feature sabse zyada vulnerable hota hai. Iske liye:

File Size Limit: Max video size set karna (jaise 100MB ya 500MB) taaki server storage crash na ho.

MIME Type Check: Sirf video/mp4, video/webm aur image formats allow karna.

Secure Filenames: Filenames ko hamesha sanitize karna (already basic level par hai, lekin uuid use karna aur bhi secure hai).

3. Rate Limiting (Prevention of Brute Force)

Brute-force attacks aur spamming se bachne ke liye:

Login/Register Limit: Ek certain limit ke baad (jaise 5 failed attempts) user ko temporary block karna.

Upload Limit: Ek user din mein kitne videos upload kar sakta hai, uski limit set karna.

4. Audit Logs (Monitoring)

Platform par hone wali important activities ka record rakhna:

Activity Collection: MongoDB mein ek logs collection banana jo record kare ki kis admin ne kab video delete kiya ya kab kisi user ka role change hua.

Security Alerts: Agar koi suspicious login activity ho (jaise different IPs se multiple logins), toh admin ko notify karna.

5. Input Validation (Data Integrity)

Injection attacks se bachne ke liye:

Zod Schemas: Saare incoming data (JSON) ko zod library use karke validate karna taaki koi malformed data DB mein na jaye.

6. Security Headers

Browser-level attacks (like XSS or Clickjacking) se bachne ke liye next.config.mjs mein security headers add karna:

Content Security Policy (CSP)

X-Frame-Options: Platform ko kisi aur website par iframe mein load hone se rokna.

7. Bot Protection (Captcha/Honeypot)

Registration aur login page par Google reCAPTCHA ya ek simple Honeypot field use karna taaki bots automatic accounts na bana sakein.

Inmein se aap kaunsa feature sabse pehle add karna chahenge? Main unhe step-by-step implement kar sakta hoon.

